

CYBERSECURITY + NETWORKING CHEAT SHEET

+ 100 INTERVIEW QUESTIONS

TCP/IP
Routers
Firewalls
Wireshark
Nmap

Security Tools
SIEM
Incident Response
Cyber Attacks
Best Practices

@codedsoul_05



NETWORKING

- TCP/IP & OSI Model
- Network Devices
- Routing & Switching
- Network Security
- IDS / IPS
- Wireshark + Nmap
- Common Protocols

CYBERSECURITY

- Cryptography
- Authentication & Authorization
- Cyber Attacks
- Malware & Phishing
- Web Security (OWASP)
- SIEM & Incident Response
- Security Best Practices

CHEAT SHEET

- Key Concepts
- Important Commands
- Tools & Use Cases
- Comparison Tables
- Port Numbers
- Common Terminology
- Real World Examples

100 INTERVIEW QUESTIONS

- Networking Basics (10)
- Network Security (10)
- Cybersecurity Concepts (10)
- Web Security (10)
- Tools & Practical (10)
- SIEM & Monitoring (10)
- Incident Response (10)
- Risk & Compliance (10)
- Advanced Topics (10)
- Scenario Based (10)

Handwritten Notes Style
20 Detailed Pages
Concepts + Examples + Diagrams
Interview Focused
Beginner to Advanced
Real World Use Cases

1. Networking Fundamentals + Network Types

What is a Computer Network ?

A computer network is a collection of interconnected devices that can communicate and share resources with each other using communication protocols.

Why do we use Networks ?

- Share data and files
- Share hardware resources (printer, storage)
- Communication (email, chat, video calls)
- Access to internet
- Centralized management
- Cost efficiency

Basic Network Communication



Key Components of a Network

- **Devices** – Computers, servers, phones, etc.
- **Medium** – Wired or wireless transmission channel
- **Protocols** – Rules for communication (e.g., TCP/IP, HTTP)
- **Network Devices** – Router, switch, firewall, etc.
- **Data** – Information being transmitted

How Does Networking Work ?

@codedsoul_05

1. Data is divided into small packets.
2. Each packet contains source, destination and control information.
3. Packets are transmitted through network devices.
4. At the destination, packets are reassembled to get the original data.



Types of Networks (Based on Coverage Area)

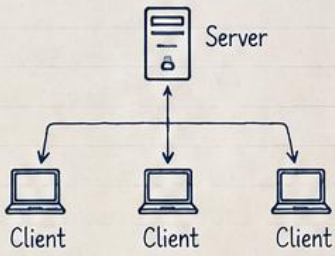
Type	Full Form	Coverage Area	Example / Use Case
PAN	Personal Area Network	1 – 10 meters	Bluetooth, mobile hotspot
LAN	Local Area Network	Home, office, building	Office network, school lab
CAN	Campus Area Network	Multiple buildings in a campus	University campus
MAN	Metropolitan Area Network	City-level	City-wide government network
WAN	Wide Area Network	Country / World	Internet, bank networks
GAN	Global Area Network	Worldwide	Internet (largest network)

Other Types of Networks

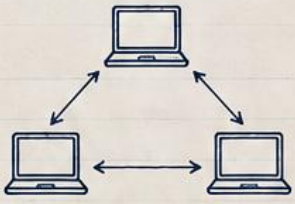
- **SAN** (Storage Area Network) – Used for storage devices
- **VPN** (Virtual Private Network) – Secure network over internet
- **WLAN** (Wireless LAN) – LAN using wireless medium (Wi-Fi)
- **BAN** (Body Area Network) – Medical devices around human body
- **CAN** (Controller Area Network) – Used in vehicles (cars)

Types of Networks (Based on Architecture)

- **Client-Server Network**
  Dedicated server provides resources to clients.



- **Peer-to-Peer (P2P) Network**
  All devices are equal and share resources directly.



2. OSI Model + TCP/IP Model

Why do we need a Model ?

- Helps in understanding how data is transmitted
- Divides complex communication into smaller layers
- Standardization (different devices can communicate)
- Troubleshooting becomes easier
- Each layer has a specific function

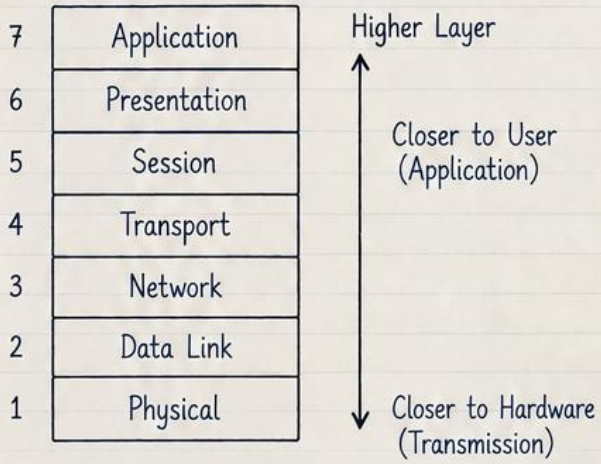
What is OSI Model ?

- OSI (Open Systems Interconnection) model is a theoretical model developed by ISO.
- It has 7 layers.
- Used for understanding network communication and not widely used in real implementations.

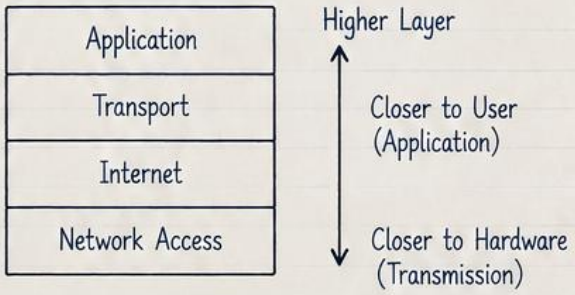
What is TCP/IP Model ?

- TCP/IP model is a practical model used in real world networks.
- It has 4 layers.
- It is the foundation of the Internet.
- Protocols like TCP, IP, HTTP, DNS work on this model.

OSI Model (7 Layers)



TCP/IP Model (4 Layers)



@codedsoul_05

OSI Model Layers and Functions

Layer	Name	Function	Example Protocols
7	Application	Provides services to user applications.	HTTP, FTP, SMTP, DNS
6	Presentation	Data formatting, encryption, compression.	SSL, TLS, JPEG, MPEG
5	Session	Manages sessions between devices.	NetBIOS, RPC
4	Transport	Provides reliable data transfer, error control.	TCP, UDP
3	Network	Handles logical addressing and routing.	IP, ICMP, IPSec
2	Data Link	Provides node to node data transfer, error detection.	Ethernet, PPP
1	Physical	Transmits raw bits over physical medium.	Cables, Hubs, Repeaters

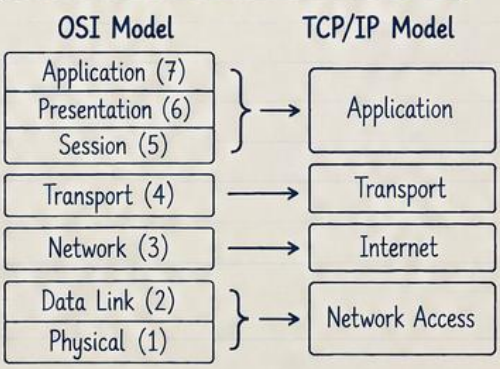
TCP/IP Model Layers and Functions

Layer	Function	Example Protocols
Application	Provides services to user applications (combines OSI 5,6,7).	HTTP, FTP, SMTP, DNS
Transport	Reliable data transfer and error control (similar to OSI 4).	TCP, UDP
Internet	Logical addressing and routing (similar to OSI 3).	IP, ICMP, IPSec
Network Access	Data link + Physical layer functions (similar to OSI 1,2).	Ethernet, Wi-Fi, PPP

Comparison: OSI vs TCP/IP

Aspect	OSI Model	TCP/IP Model
Developed by	ISO	DoD (DARPA)
Number of Layers	7	4
Nature	Theoretical	Practical
Layer Separation	Strict	Flexible
Usage	Learning, troubleshooting	Real world implementation
Layer Mapping	Each layer defined clearly	Combines multiple layers

Layer Mapping (OSI to TCP/IP)



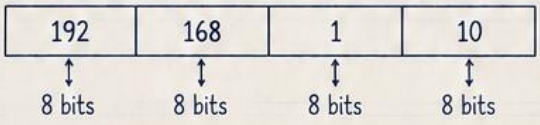
3. IP Addressing + Subnetting

What is an IP Address ?

- An IP address is a unique numerical identifier assigned to a device in a network.
- It is used to identify devices and enable communication between them.
- Works at the Network layer (Layer 3).

IPv4 Address Structure

An IPv4 address is 32 bits, divided into 4 octets (8 bits each).

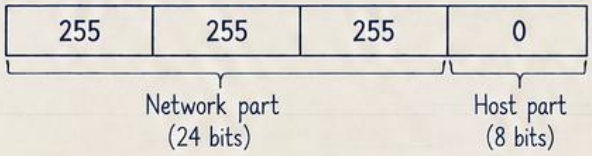


Types of IPv4 Addresses

Type	Range	Use Case
Private	10.0.0.0 – 10.255.255.255 172.16.0.0 – 172.31.255.255 192.168.0.0 – 192.168.255.255	Used in internal networks (not routable on internet)
Public	All other addresses	Used on the internet
Loopback	127.0.0.0 – 127.255.255.255	Used for testing (e.g., 127.0.0.1)
Link-local	169.254.0.0 – 169.254.255.255	Automatic IP assignment when DHCP fails

Subnet Mask

- A subnet mask is used to identify the network portion and host portion of an IP address.
- It also has 32 bits.



Classes of IP Addresses (Legacy)

Class	First Octet Range	Default Subnet Mask	Use Case
A	1 – 126	255.0.0.0	Large networks
B	128 – 191	255.255.0.0	Medium networks
C	192 – 223	255.255.255.0	Small networks
D	224 – 239	–	Multicast
E	240 – 255	–	Experimental

Important Points

- Network address: first IP in the subnet (cannot be assigned).
- Broadcast address: last IP in the subnet (cannot be assigned).
- Usable IP range: total IPs – 2.
- More subnet bits → more subnets but fewer hosts per subnet.
- CIDR is preferred over classful addressing.

Types of IP Addresses

- IPv4 – 32 bits (e.g., 192.168.1.1)
- IPv6 – 128 bits (e.g., 2001:0db8:85a3::8a2e:0370:7334)

IPv4 vs IPv6

Feature	IPv4	IPv6
Size	32 bits	128 bits
Address space	≈ 4.3 billion	≈ 3.4×10^{38}
Notation	Decimal (e.g., 192.168.1.1)	Hexadecimal (e.g., 2001:db8::1)
Used	Widely used	Used for future growth

What is Subnetting ?

- Subnetting is the process of dividing a larger network into smaller networks (subnets).
- Helps in efficient use of IP addresses and better network management.

@codedsoul_05

CIDR Notation

- CIDR (Classless Inter-Domain Routing) is used to represent IP addresses and subnet masks.
- Example: 192.168.1.0/24
- Here 24 means first 24 bits are network part.

Subnetting Example 1

Given IP: 192.168.1.0/24
Subnet mask: 255.255.255.0

- Total IP addresses = $2^{(32-24)}$ = 256
- Usable IP addresses = 256 – 2 = 254
- Network address = 192.168.1.0
- Broadcast address = 192.168.1.255
- Usable range = 192.168.1.1 – 192.168.1.254

Subnetting Example 2 (Divide into 4 subnets)

Given: 192.168.1.0/24
Need: 4 subnets → Borrow 2 bits ($2^2 = 4$)
New prefix: /26 Subnet mask: 255.255.255.192

Subnet No.	Network Address	Usable Range	Broadcast Address
1	192.168.1.0	192.168.1.1 – 62	192.168.1.63
2	192.168.1.64	192.168.1.65 – 126	192.168.1.127
3	192.168.1.128	192.168.1.129 – 190	192.168.1.191
4	192.168.1.192	192.168.1.193 – 254	192.168.1.255

Quick Formulas

- Total IP addresses = $2^{(32-n)}$ (n = prefix length)
- Usable IP addresses = $2^{(32-n)} - 2$
- Number of subnets = 2^s (s = number of borrowed bits)
- Hosts per subnet = $2h - 2$ (h = number of host bits)

4. MAC Address + ARP

What is a MAC Address ?

- MAC (Media Access Control) address is a unique hardware address assigned to a network interface card (NIC).
- It works at the Data Link Layer (Layer 2) of OSI model.
- Used to identify a device in a local network (LAN).
- It is a 48-bit address (6 bytes) written in hexadecimal format.

MAC Address Format



Total = 48 bits (6 bytes)

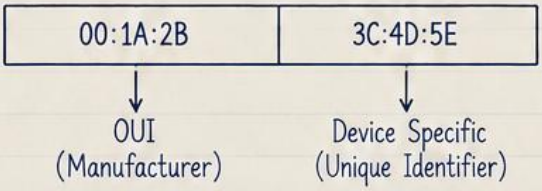
Example: 00:1A:2B:3C:4D:5E

Types of MAC Addresses

Type	Description	Example
Unicast	Identifies a single device	00:1A:2B:3C:4D:5E
Multicast	Identifies a group of devices	01:00:5E:00:00:FB
Broadcast	Identifies all devices in the network	FF:FF:FF:FF:FF:FF

How is MAC Address Assigned ?

- Assigned by the manufacturer (burned into NIC).
- First 24 bits – OUI (Organizationally Unique Identifier) identifies manufacturer.
- Last 24 bits – unique identifier given by manufacturer.



Important Points about MAC Address

- Works only in local network (LAN).
- Cannot be changed easily (but can be spoofed).
- Used for frame delivery at Data Link Layer.
- Different from IP address (IP can change, MAC is fixed).
- Each network interface has its own MAC address.
- Shown using commands like ipconfig / ifconfig.

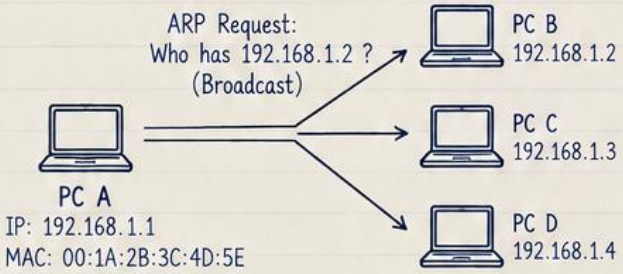
What is ARP ?

- ARP (Address Resolution Protocol) is used to find the MAC address of a device when we know its IP address.
- It works at the Data Link Layer (Layer 2).
- It maintains an ARP cache (IP → MAC mapping).
- Used in IPv4 networks (not used in IPv6, which uses Neighbor Discovery Protocol).

How ARP Works ?

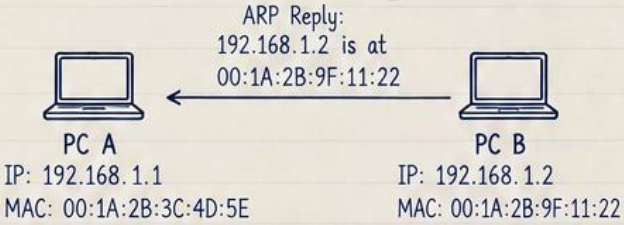
1. Sender checks its ARP cache for the destination IP.
2. If not found, it sends an ARP Request (broadcast) to ask "Who has this IP?"
3. The device with that IP sends an ARP Reply (unicast) with its MAC address.
4. The sender updates its ARP cache and sends the data to the destination MAC address.

ARP Request (Broadcast)



ARP Reply (Unicast)

@codedsoul_05



ARP Cache

- Stores IP to MAC address mappings temporarily (for some time).
- If the entry is not found, ARP request is sent again.
- Can be viewed using commands.

Common Commands

Operating System	View ARP Cache	Clear ARP Cache
Windows	arp -a	arp -d *
Linux	arp -n	sudo arp -d *
macOS	arp -a	sudo arp -d *

5. TCP + UDP + Ports

What is TCP ?

- TCP (Transmission Control Protocol) is a connection-oriented protocol.
- It provides reliable, ordered and error-free data delivery.
- Uses 3-way handshake to establish a connection. Used in applications where data integrity is important (e.g., web browsing, file transfer, email).

What is UDP ?

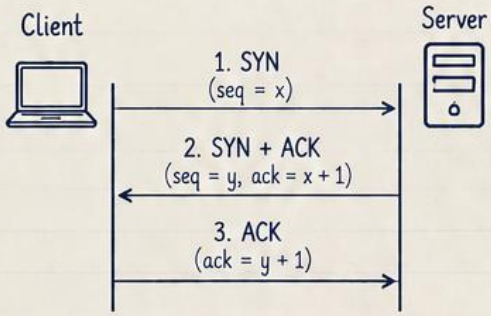
- UDP (User Datagram Protocol) is a connectionless protocol.
- It does not guarantee delivery, order or error correction.
- It is faster and has low overhead.
- Used in applications where speed is important (e.g., video streaming, online gaming, DNS).

TCP vs UDP (Comparison)

Feature	TCP	UDP
Connection	Connection-oriented	Connectionless
Reliability	Reliable	Not reliable
Ordering	Maintains order	Does not maintain order
Error control	Yes (ACK, retransmission)	No
Speed	Slower	Faster
Header size	20 bytes (minimum)	8 bytes
Use case	Web, email, file transfer	Video streaming, gaming, DNS, VoIP

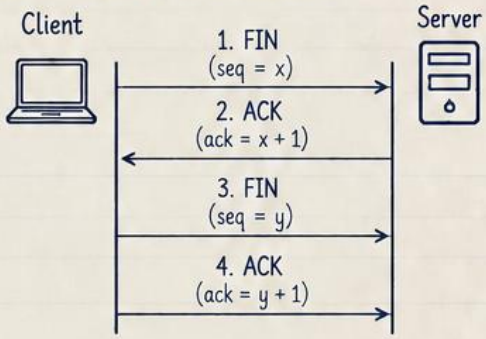
TCP 3-Way Handshake

Used to establish a TCP connection.



TCP 4-Way Termination

Used to close a TCP connection.



TCP Header Format (20 Bytes Minimum)

0			16	31
Source Port (16 bits)			Destination Port (16 bits)	
Sequence Number (32 bits)				
Acknowledgment Number (32 bits)				
Data Offset (4 bits)	Reserved (3 bits)	Flags (9 bits)	Window Size (16 bits)	
Checksum (16 bits)			Urgent Pointer (16 bits)	
Options (0 – 40 bytes)				
Data (Variable size)				

UDP Header Format (8 Bytes)

0	16	31
Source Port (16 bits)	Destination Port (16 bits)	
Length (16 bits)	Checksum (16 bits)	
Data (Variable size)		

TCP Flags

Flag	Description
SYN	Synchronize (start connection)
ACK	Acknowledge (confirm receipt)
FIN	Finish (close connection)
RST	Reset (abort connection)
PSH	Push (send data immediately)
URG	Urgent (high priority data)

Common Ports

Port No.	Protocol	Service / Use Case
20	TCP	FTP (Data)
21	TCP	FTP (Control)
22	TCP	SSH (Secure Shell)
23	TCP	Telnet
25	TCP	SMTP (Email)
53	TCP/UDP	DNS (Domain Name System)
80	TCP	HTTP
443	TCP	HTTPS
110	TCP	POP3 (Email)
143	TCP	IMAP (Email)
3306	TCP	MySQL
3389	TCP	RDP (Remote Desktop)

Important Points

- Port number identifies the application process on a device.
- TCP ensures reliable communication.
- UDP is used when speed is more important than reliability.
- Well-known ports: 0 – 1023
- Registered ports: 1024 – 49151
- Dynamic/Private ports: 49152 – 65535

6. DNS + DHCP

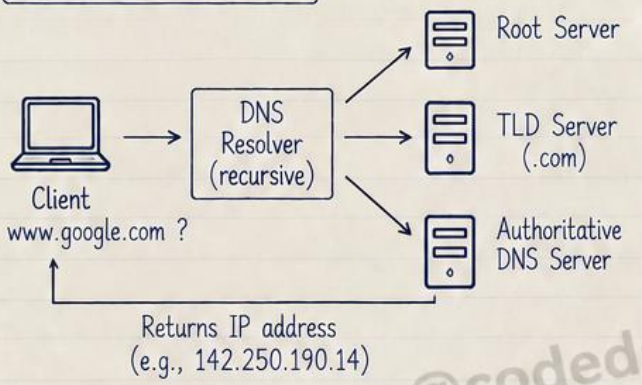
What is DNS ?

- DNS (Domain Name System) is a distributed and hierarchical naming system.
- It converts human-readable domain names (e.g., www.google.com) into IP addresses (e.g., 142.250.190.14).
- It works at the Application layer (Layer 7).
- Uses UDP port 53 (mostly) and TCP port 53 (for large responses or zone transfers).

Why do we need DNS ?

- Humans remember domain names easily.
- IP addresses are difficult to remember.
- DNS makes it possible to access websites using domain names.

How DNS Works ?



Types of DNS

- Recursive DNS – Queries on behalf of the client.
- Iterative DNS – Refers to the next server.
- Authoritative DNS – Holds the actual domain records.
- Caching DNS – Stores previous queries to speed up response.

Types of DNS Records

Record Type	Description
A	Maps domain name to IPv4 address
AAAA	Maps domain name to IPv6 address
CNAME	Alias for another domain name
MX	Specifies mail server
NS	Specifies authoritative name server
PTR	Used for reverse DNS lookup
TXT	Stores text information (e.g., SPF, DKIM)
SOA	Start of Authority (zone information)
SRV	Specifies service location (e.g., VoIP)

Example DNS Query

User types: www.google.com
↓
DNS resolves to: 142.250.190.14
↓
Browser connects to this IP address.

@codedsoul_05

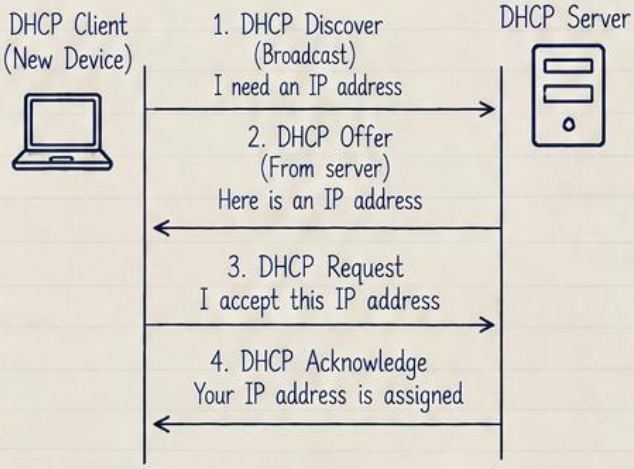
What is DHCP ?

- DHCP (Dynamic Host Configuration Protocol) is used to automatically assign IP configuration to devices in a network.
- It works at the Network layer (Layer 3).
- Uses UDP ports 67 (server) and 68 (client).
- It provides IP address, subnet mask, default gateway, and DNS server to clients.

Why do we need DHCP ?

- Manually configuring IP addresses is time consuming.
- DHCP automates the process.
- Helps in efficient management of IP addresses.
- Reduces configuration errors.

How DHCP Works ? (DORA Process)



DHCP Messages (DORA)

Message	Type	Description
Discover	Broadcast	Client searches for available DHCP servers.
Offer	Unicast	Server offers an available IP address.
Request	Broadcast	Client requests the offered IP address.
Acknowledge	Unicast	Server confirms and assigns the IP address.

Information Provided by DHCP

- IP address
- Subnet mask
- Default gateway
- DNS server address
- Lease time (validity period)
- Domain name (optional)

7. HTTP + HTTPS + Web Networking

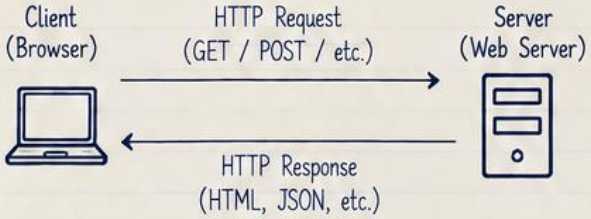
What is Web Networking ?

- Web networking refers to the communication between clients (browsers) and servers over the internet using protocols like HTTP and HTTPS.
- It follows the client-server model.
- Web pages, APIs, and other resources are accessed using URLs.
- Works at the Application layer (Layer 7) of the OSI model.

What is HTTP ?

- HTTP (Hypertext Transfer Protocol) is a stateless application layer protocol used to transfer data over the web.
- It is used to access web pages, APIs, and other resources.
- HTTP does not provide encryption, so data is sent in plain text.
- Default port: 80

HTTP Request and Response



Example HTTP Request

```
GET /index.html HTTP/1.1
Host: www.example.com
User-Agent: Mozilla/5.0
Accept: text/html
```

Example HTTP Response

```
HTTP/1.1 200 OK
Content-Type: text/html
Content-Length: 1256

<html> ... </html>
```

Common HTTP Methods

Method	Description	Use Case
GET	Retrieves data	Get a web page or resource
POST	Sends data to server	Submit forms, create data
PUT	Updates existing data	Update a resource
DELETE	Deletes data	Remove a resource
PATCH	Partially updates data	Update specific fields
HEAD	Retrieves headers only	Check resource info
OPTIONS	Returns allowed methods	Check server capabilities

What is HTTPS ?

- HTTPS (Hypertext Transfer Protocol Secure) is the secure version of HTTP.
- It uses SSL/TLS encryption to protect data between client and server.
- Ensures confidentiality, integrity, and authentication.
- Default port: 443

How HTTPS Works ?



@codedsoul_05

HTTP vs HTTPS (Comparison)

Feature	HTTP	HTTPS
Full Form	Hypertext Transfer Protocol	Hypertext Transfer Protocol Secure
Security	Not secure (plain text)	Secure (encrypted using SSL/TLS)
Port	80	443
Data Encryption	No	Yes
Use Case	Normal websites	Banking, login, sensitive data
Performance	Slightly faster	Slightly slower (due to encryption)

Web Networking Components

Component	Description
Client	Sends a request (browser, mobile app, etc.)
Server	Processes request and sends response
URL	Address of the resource (e.g., https://example.com)
DNS	Resolves domain name to IP address
IP Address	Identifies the server
Ports	Identify the service (80 for HTTP, 443 for HTTPS)
Protocols	HTTP, HTTPS, TCP, TLS, etc.

Important Points

- HTTP is stateless, each request is independent.
- HTTPS uses SSL/TLS for encryption.
- Web communication typically uses TCP.
- Domain name is resolved using DNS before sending request.
- Browsers verify SSL certificates to ensure authenticity.
- Modern websites use HTTPS for security and trust.
- Web networking involves multiple layers: DNS → TCP → TLS (HTTPS) → HTTP → Application data.

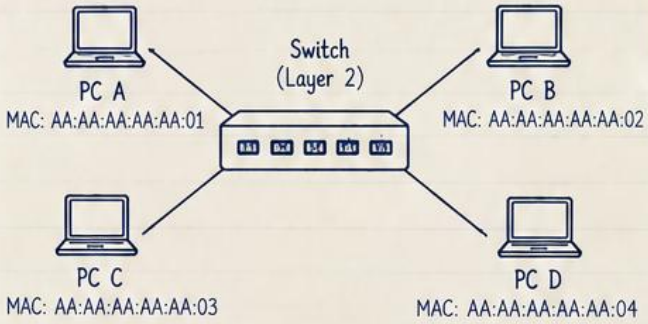
8. Routing + Switching

What is Switching ?

- A switch is a Layer 2 (Data Link Layer) device used to connect devices within the same local network (LAN).
- It forwards data frames based on MAC addresses.
- It creates a separate collision domain for each port.
- It uses a MAC address table to learn and forward frames.

How a Switch Works ?

1. Learns the source MAC address from incoming frame.
2. Stores it in the MAC address table with the port number.
3. If destination MAC is known → forwards only to that port.
4. If destination MAC is unknown → floods the frame to all ports (except the incoming port).



MAC Address Table (Switch)

MAC Address	Port	Type	Aging Time
AA:AA:AA:AA:AA:01	1	Dynamic	300 sec
AA:AA:AA:AA:AA:02	2	Dynamic	300 sec
AA:AA:AA:AA:AA:03	3	Dynamic	300 sec
AA:AA:AA:AA:AA:04	4	Dynamic	300 sec

Types of Switching

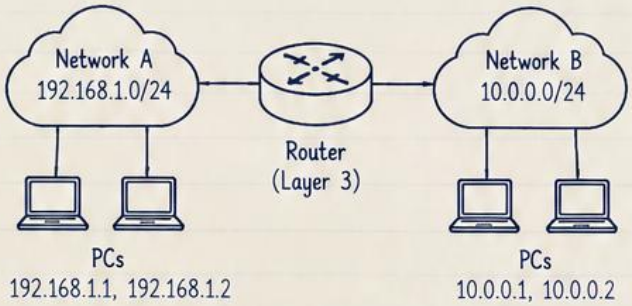
- Store and Forward – Checks entire frame for errors.
- Cut Through – Forwards frame immediately (faster).
- Fragment Free – Forwards after first 64 bytes.

What is Routing ?

- A router is a Layer 3 (Network Layer) device used to connect different networks.
- It forwards data packets based on IP addresses.
- It uses routing tables to find the best path.
- It can connect LAN to WAN (e.g., internet).
- It can perform additional functions like NAT, firewall, DHCP, etc.

How a Router Works ?

1. Receives a packet and checks the destination IP address.
2. Looks up the routing table for the best route.
3. Forwards the packet to the next hop or directly to the destination network.
4. If no route is found, it uses a default route.



Routing Table (Router)

Destination Network	Subnet Mask	Next Hop	Interface
192.168.1.0	255.255.255.0	Direct	Gig0/0
10.0.0.0	255.255.255.0	Direct	Gig0/1
0.0.0.0	0.0.0.0	103.1.1.1	Gig0/1

Types of Routing

- Static Routing – Manually configured routes.
- Dynamic Routing – Routes learned automatically.
- Default Routing – Used when no specific route is found.
- Routing Protocols – e.g., RIP, OSPF, EIGRP, BGP.

Switch vs Router (Comparison)

@codedl_os

Feature	Switch	Router
OSI Layer	Layer 2 (Data Link)	Layer 3 (Network)
Address used	MAC Address	IP Address
Purpose	Connect devices in same LAN	Connect different networks
Routing	No	Yes
Broadcast domain	One (per VLAN)	Multiple
Collision domain	Separate per port	Separate per port
Example	LAN connectivity	LAN to WAN, internet

Key Differences in Use Case

- Use a switch to connect multiple devices within the same network (e.g., office LAN).
- Use a router to connect different networks (e.g., office LAN to internet).
- Switch works with MAC addresses, router works with IP addresses.
- Switch does not route traffic, router does.
- A router can also perform NAT, DHCP, firewall, and other network functions.

Important Points

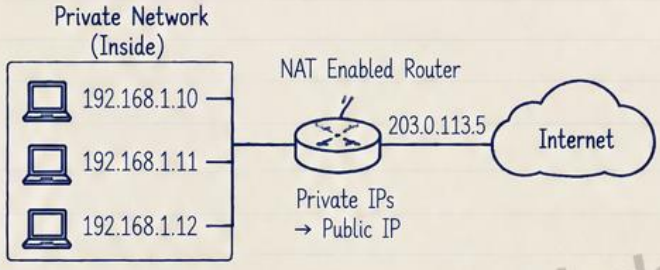
- Switching works at Layer 2, routing works at Layer 3.
- Switch builds MAC address table, router builds routing table.
- Router can connect multiple networks, switch works within a single network.

9. NAT + PAT + VPN

What is NAT ?

- NAT (Network Address Translation) is a technique used to translate private IP addresses into a public IP address so that multiple devices in a private network can access the internet.
- It is usually configured on a router or firewall.
- NAT helps in conserving public IP addresses and adds a level of security by hiding internal IP addresses.

How NAT Works ?



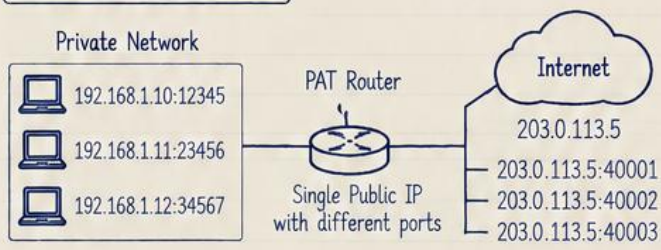
Types of NAT

Type	Description	Use Case
Static NAT	One-to-one mapping (private to public)	Used for servers (e.g., web server)
Dynamic NAT	Maps private IP to a public IP from a pool	Used in organizations with limited public IPs
PAT (NAT Overload)	Multiple private IPs share a single public IP using different ports	Most commonly used in home and office networks

What is PAT (Port Address Translation) ?

- PAT is a form of NAT where multiple private IP addresses are translated to a single public IP address using different port numbers.
- It is also called NAT Overload.
- It allows many devices to access the internet using one public IP.

How PAT Works ?



NAT vs PAT (Comparison)

Feature	NAT (Static/Dynamic)	PAT (NAT Overload)
Public IP used	One or few	Single public IP
Translation	IP only	IP + Port
Mapping	One-to-one or one-to-many	Many-to-one
Use case	Servers or organization	Home and office networks
Port numbers	Not required	Required

Why NAT and PAT are Used ?

- Conserves public IP addresses
- Allows multiple devices to access the internet
- Hides internal network structure (security)
- Helps in IP address overlapping (same private IPs in different networks)
- Used in home routers, office firewalls, and enterprise networks

What is VPN ?

- VPN (Virtual Private Network) creates a secure and encrypted connection over a public inetwork (usually the internet).
- It allows remote users to access a private network as if they are in the same local network.
- It ensures confidentiality, integrity, and security of data.

@codedsoul_05

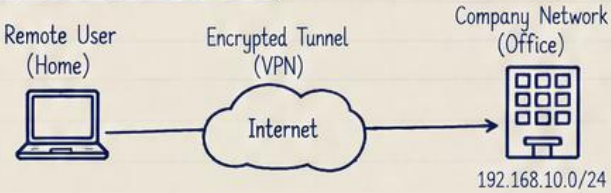
Why do we use VPN ?

- Secure remote access to company resources
- Encrypts data over public networks (e.g., Wi-Fi)
- Access restricted internal systems
- Bypass network restrictions (e.g., geo-blocking)
- Connect different branches securely (site-to-site VPN)

Types of VPN

Type	Description	Use Case
Remote Access VPN	Allows individual users to connect to a private network	Work from home, remote employees
Site-to-Site VPN	Connects two or more networks over the internet	Connect office branches
Client-based VPN	Requires VPN software on device	Individual users
SSL VPN	Uses SSL/TLS for secure access	Web-based access
IPSec VPN	Uses IPSec protocol for encryption	Enterprise networks

How VPN Works ?



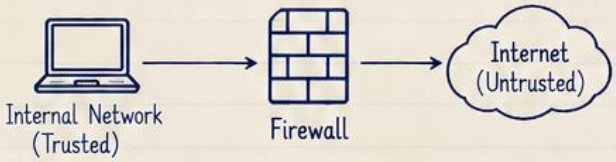
NAT + PAT + VPN (Key Points)

- NAT translates private IPs to public IPs.
- PAT allows multiple private IPs to share one public IP using port numbers.
- VPN creates a secure encrypted tunnel over the internet.
- NAT and PAT are mainly used for internet access.
- VPN is used for secure communication and remote access.
- NAT/PAT hide internal IP addresses, while VPN encrypts data.

10. Firewalls + Proxy Servers

What is a Firewall ?

- A firewall is a network security device or software that monitors and controls incoming and outgoing network traffic based on predefined security rules.
- It acts as a barrier between a trusted internal network and an untrusted external network (e.g., the internet).
- It can allow or block traffic based on IP address, port number, protocol, and application.



How a Firewall Works ?

1. Examines each packet of data.
2. Checks it against a set of security rules.
3. Allows the packet if it matches a rule.
4. Blocks the packet if it violates the rule.

@codedsoul_05

Types of Firewalls

Type	Description	Use Case
Packet Filtering Firewall	Filters packets based on IP, port, and protocol (Layer 3/4).	Basic filtering, home networks.
Stateful Inspection Firewall	Tracks the state of active connections and makes decisions based on context (Layer 3/4).	Enterprise networks.
Application Layer Firewall	Inspects data at application layer (Layer 7).	Blocks malicious web traffic.
Next Generation Firewall (NGFW)	Combines traditional firewall with advanced features like IDS, IPS, application control.	Modern enterprise security.

Common Firewall Rules

Rule	Action	Example
Allow HTTP	Allow	TCP port 80
Allow HTTPS	Allow	TCP port 443
Block Telnet	Deny	TCP port 23
Allow specific IP	Allow	Allow 192.168.1.0/24
Deny all others	Deny	Block all other traffic

Firewall vs IDS vs IPS

Feature	Firewall	IDS (Intrusion Detection)	IPS (Intrusion Prevention)
Main Purpose	Allow/Block traffic	Detects threats	Detects and blocks threats
Action	Block/Allow	Alert only	Block automatically
Position	Network edge	Inside network	Inside network or edge
Example	Cisco ASA, FortiGate	Snort	Snort (IPS mode), Suricata

What is a Proxy Server ?

- A proxy server acts as an intermediary between a client and the internet.
- It receives requests from clients, forwards them to the destination server, and returns the response to the client.
- It hides the client's IP address and can also perform filtering, caching, and access control.



How a Proxy Server Works ?

1. Client sends a request to the proxy server.
2. Proxy server forwards the request to the destination server on behalf of the client.
3. Destination server sends the response to the proxy server.
4. Proxy server returns the response to the client.

Types of Proxy Servers

Type	Description	Use Case
Forward Proxy	Sits between client and internet. Hides client's IP.	Used by organizations to control and monitor internet access.
Reverse Proxy	Sits between internet and internal servers. Hides server's IP.	Used for load balancing, security, and caching.
Transparent Proxy	Intercepts traffic without client configuration.	Used by ISPs, schools, companies.
Anonymous Proxy	Hides client's IP address.	Privacy and browsing anonymously.
Caching Proxy	Stores frequently accessed content.	Improves performance and reduces bandwidth.

Forward Proxy vs Reverse Proxy

Feature	Forward Proxy	Reverse Proxy
Position	Between client and internet	Between internet and server
Hides	Client's IP address	Server's IP address
Use Case	Control client access, filtering, caching	Load balancing, security, SSL termination
Example	Squid, Blue Coat	Nginx, HAProxy

Firewall vs Proxy Server (Comparison)

Feature	Firewall	Proxy Server
Main Purpose	Allow or block network traffic	Act as an intermediary
Layer	Network (L3/L4) and Application (L7)	Application (L7)
Hides IP	No (generally)	Yes (client or server)
Filters Content	Based on rules (IP, port, protocol)	Yes (URL, content, etc.)
Caching	No	Yes
Use Case	Network security	Access control, caching, privacy, performance
Example	Cisco Firewall, FortiGate	Squid (forward), Nginx (reverse)

Key Takeaways

- A firewall protects the network by allowing or blocking traffic based on rules.
- A proxy server acts as an intermediary to control, filter, and optimize web access.
- Firewalls work at multiple layers, while proxies mainly work at the application layer.
- Both are used together in organizations for security, performance, and access control.

11. Cybersecurity Fundamentals

What is Cybersecurity ?

- Cybersecurity is the practice of protecting computers, networks, applications, data, and users from attacks, damage, or unauthorized access.
- It ensures the confidentiality, integrity, and availability of information.
- It includes people, processes, and technologies to defend against cyber threats.

Goals of Cybersecurity (CIA Triad)

Goal	Meaning	Example
Confidentiality	Only authorized users can access data.	Encryption, Access Control
Integrity	Data is not modified without authorization.	Hashing, Digital Signatures
Availability	Data and services are available when needed.	Backups, Redundancy, DDoS Protection

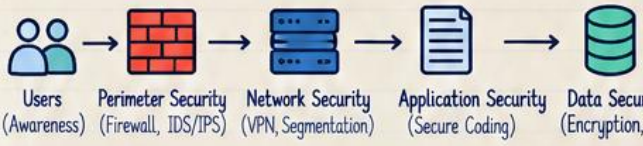
Common Cyber Threats

Threat	Description
Malware	Malicious software (virus, worm, trojan, ransomware).
Phishing	Tricks users to steal sensitive information.
Ransomware	Encrypts data and demands payment.
DDoS Attack	Floods a server with traffic to make it unavailable.
Man-in-the-Middle	Intercepts communication between two parties.
SQL Injection	Exploits database queries to access data.
Zero-day Attack	Exploits unknown vulnerabilities.
Insider Threat	Threat from within the organization.

Types of Cyber Attacks



Cybersecurity Layers (Defense in Depth)



@codedsoul_05

Common Security Terms

Term	Meaning
Vulnerability	Weakness in a system that can be exploited.
Exploit	Code or method to take advantage of a vulnerability.
Threat	Potential cause of an unwanted incident.
Risk	Likelihood and impact of a threat.
Attack	Attempt to exploit a vulnerability.
Authentication	Verifying the identity of a user.
Authorization	Determining what a user can access.
Encryption	Converting data into a secret form.
Decryption	Converting encrypted data back to original form.

Authentication Methods

Type	Description
Something You Know	Password, PIN
Something You Have	OTP, Security Token, Mobile
Something You Are	Biometric (Fingerprint, Face)
Multi-Factor Authentication (MFA)	Combination of two or more methods



Encryption Basics

- Encryption converts readable data (plaintext) into unreadable data (ciphertext) using an algorithm and a key.
- Only authorized users with the correct key can decrypt it.



Types of Encryption

Type	Description	Example
Symmetric Encryption	Same key for encryption and decryption.	AES, DES
Asymmetric Encryption	Public key for encryption, private key for decryption.	RSA, ECC
Hashing	Converts data into a fixed length hash (one way).	SHA-256, MD5

Best Practices for Cybersecurity

1. Use strong and unique passwords.
2. Enable multi factor authentication (MFA).
3. Keep software and systems updated.
4. Use firewalls and antivirus software.
5. Follow the principle of least privilege.
6. Regularly backup data.
7. Be cautious of phishing emails.
8. Use encryption for sensitive data.
9. Monitor and log network activity.
10. Conduct regular security audits.

Key Takeaways

- Cybersecurity protects systems, data, and users.
- CIA triad ensures confidenticality, integrity, and availability.
- Many types of attacks target different layers.
- Encryption, authentication, and access control are key tools.
- Following best practices reduces the risk of cyber threats.

12. Cryptography + Encryption + Hashing

What is Cryptography ?

- Cryptography is the science of securing information using mathematical techniques.
- It helps in confidentiality, integrity, authentication and non-repudiation.
- It includes encryption, decryption, hashing, digital signatures, and key management.
- Used in secure communication, secure data storage, passwords, and digital certificates.

Encryption vs Decryption

- **Encryption** converts readable data (plaintext) into unreadable data (ciphertext) using an algorithm and a key.
- **Decryption** converts ciphertext back to plaintext using the correct key.



@codedsoul_05

Symmetric Encryption

- Uses the same secret key for both encryption and decryption.
- Faster and suitable for large data.
- Common algorithms: AES, DES, 3DES, Blowfish.



Common Encryption Algorithms

Algorithm	Type	Key Size	Use Case
AES	Symmetric	128, 192, 256 bits	Most widely used, secure and fast
DES	Symmetric	56 bits	Old, not secure now
3DES	Symmetric	168 bits	Legacy systems
RSA	Asymmetric	1024, 2048, 4096 bits	Key exchange, digital signatures
ECC	Asymmetric	160–521 bits	Used in modern systems (mobile, IoT)

Common Hashing Algorithms

Algorithm	Hash Size	Use Case	Status
MD5	128 bits	File integrity (legacy)	Not secure (collisions)
SHA-1	160 bits	Legacy systems	Not secure
SHA-256	256 bits	Widely used, secure	Secure
SHA-512	512 bits	High security	Secure
bcrypt	Adaptive	Password hashing	Secure (recommended)
Argon2	Adaptive	Password hashing	Most secure (modern)

Real World Examples

- HTTPS uses encryption (TLS) for secure communication.
- Passwords are stored as hashed values (bcrypt or Argon2).
- Digital signatures are used in software updates and certificates.
- Cryptography is used in VPN, SSL/TLS, blockchain, and secure messaging apps.

Goals of Cryptography

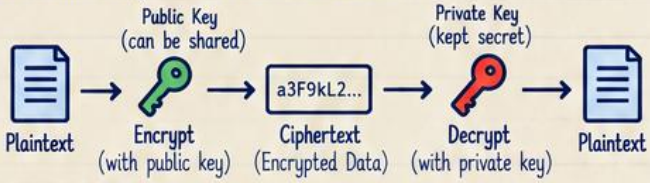
Goal	Meaning	Example
Confidentiality	Only authorized users can access data.	Encryption (AES, RSA)
Integrity	Data is not modified without detection.	Hashing (SHA-256), Digital Signatures
Authentication	Verify the identity of a user or system.	Passwords, Certificates, MFA
Non-repudiation	Sender cannot deny sending the data.	Digital Signatures
Availability	Data is accessible when needed.	Secure and resilient systems

Types of Cryptography

Type	Description	Example	Use Case
Symmetric Encryption	Same key for encryption and decryption.	AES, DES, 3DES	Fast, used for large data.
Asymmetric Encryption	Public key for encryption, private key for decryption.	RSA, ECC	Secure key exchange, digital signatures.
Hashing	One-way function (irreversible).	SHA-256, MD5	Data integrity, password storage.
Digital Signature	Uses private key to sign data.	RSA, DSA, ECDSA	Authentication, non-repudiation.

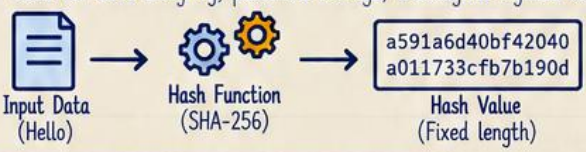
Asymmetric Encryption (Public Key Cryptography)

- Uses a pair of keys: public key and private key.
- Data encrypted with public key can only be decrypted with private key.
- Slower than symmetric encryption but more secure for key exchange.
- Common algorithms: RSA, ECC, ElGamal.



Hashing

- Hashing converts data into a fixed-length string (hash) using a one-way function.
- It is irreversible, meaning original data cannot be obtained from hash.
- Even a small change in input produces a completely different hash.
- Used for data integrity, password storage, and digital signatures.



Encryption vs Hashing (Comparison)

Feature	Encryption	Hashing
Purpose	Confidentiality (hide data)	Integrity (verify data)
Reversible	Yes (with key)	No (one-way)
Output	Ciphertext (variable length)	Fixed-length hash
Key required	Yes	No
Use case	Secure communication, data storage	Password storage, file integrity, digital signatures

Key Takeaways

- Encryption protects the confidentiality of data.
- Hashing ensures data integrity and is irreversible.
- Symmetric encryption is fast but requires secure key sharing.
- Asymmetric encryption is secure for key exchange and digital signatures.
- Choose the right algorithm based on security needs and use case.

13. Authentication + Authorization + Access Control

What are they ?

- Authentication verifies who you are.
- Authorization decides what you can do.
- Access Control is the mechanism, policies, and rules used to enforce authorization.
- These three work together to secure systems, applications, and data.



Authentication

- Authentication is the process of *verifying the identity* of a user, device, or system.
- Common methods: password, OTP, biometrics, tokens, certificates, OAuth, SSO.
- After successful authentication, the user gets a session or access token.

@codedsoul_05

Authentication Methods



Access Control

- Access Control is the implementation of authorization rules to allow or deny access.
- It defines and enforces who can access what resources (e.g., files, APIs, databases, applications).
- It can be implemented using models like RBAC, ABAC, ACL, and policies.

Access Control Flow

@codedsoul_05



Key Differences

Aspect	Authentication	Authorization	Access Control
Purpose	Verify identity	Decide permissions	Enforce permissions
Question	Who are you?	What can you do?	How do we enforce it?
Occurs	During login	After authentication	Every time a resource is accessed
Example	Password, OTP, Biometric, Token	Can user edit a file?	Allow or deny access to file based on rules
Result	Authenticated user (identity confirmed)	Permission granted or denied	Access allowed or blocked

Authorization

- Authorization decides what an authenticated user is allowed to do.
- It checks the user's permissions or roles before allowing access to a resource.
- It happens after authentication.
- Example: a normal user can view a file, but an admin can edit or delete it.

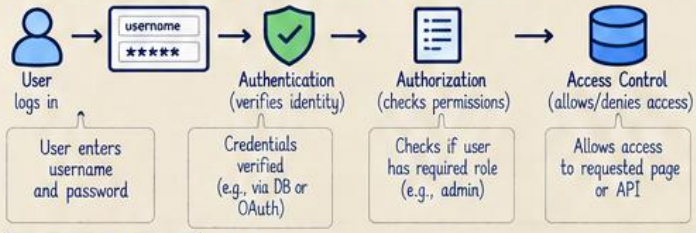
Authorization Models



Access Control Models (Detailed)

Model	Description	Use Case	Example
DAC (Discretionary)	Owner decides who can access.	Personal files, small systems	File owner shares file with another user
MAC (Mandatory)	Access controlled by system policies.	Government, military systems	Classified data access
RBAC (Role Based)	Permissions based on user roles.	Enterprise applications	Admin, Manager, Employee
ABAC (Attribute Based)	Permissions based on attributes.	Complex, dynamic environments	Access based on user location, device, time, department
ACL (Access Control List)	Resource has a list of allowed users.	Files, folders, network resources	Specific users can read or write

Real World Example (Web Application)



Common Authentication Protocols

Protocol	Description
OAuth 2.0	Authorization framework for secure access to APIs.
OpenID Connect	Identity layer on top of OAuth 2.0 (authentication).
SAML	Used for Single Sign On (SSO) in enterprises.
JWT (JSON Web Token)	Token based authentication for APIs and web apps.
Kerberos	Network authentication protocol (used in organizations).
LDAP	Directory service for authentication and user management.

Common Terms

Term	Meaning
Identity	Unique identifier of a user (e.g., email, username).
Credential	Something used to verify identity (password, token, etc.).
Permission	Specific action allowed (e.g., read, write, delete).
Role	Collection of permissions (e.g., admin, editor, viewer).
Policy	Set of rules defining access rights.
Token	Used for secure authentication (e.g., JWT, OAuth token).

Key Takeaways

- Authentication verifies your identity.
- Authorization decides what you can do.
- Access Control enforces the rules and restrictions.
- Use strong authentication methods (MFA) for better security.
- Use appropriate access control models (RBAC, ABAC, ACL) based on use case.
- Follow the principle of least privilege (give only required access).
- These concepts are fundamental for securing modern applications and systems.

14. Common Cyber Attacks + Attack Lifecycle

What are Cyber Attacks ?

- Cyber attacks are deliberate attempts to gain unauthorized access, steal, modify, or destroy data, disrupt services, or gain control over systems and networks.
- Attackers exploit vulnerabilities in people, processes, or technology to achieve their goals.

Goals of Cyber Attacks



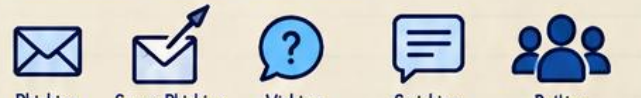
Common Cyber Attacks

Attack Type	Description	Example	Impact
Malware	Malicious software that harms a system.	Virus, Worm, Trojan, Ransomware	Data loss, system damage
Phishing	Tricks users to share sensitive information.	Fake email or website	Credential theft, financial loss
Ransomware	Encrypts data and demands payment.	WannaCry, LockBit	Data loss, business disruption
DDoS Attack	Floods a server with traffic to make it unavailable.	Botnet traffic	Service downtime
SQL Injection	Exploits database queries to access data.	OR 1=1 --	Data breach, unauthorized access
Cross-Site Scripting (XSS)	Injects malicious scripts into websites.	Steal user cookies	Account takeover
Man-in-the-Middle (MitM)	Intercepts communication between two parties.	Public Wi-Fi sniffing	Data theft, session hijacking
Brute Force Attack	Tries many combinations to guess credentials.	Password cracking tools	Unauthorized access
Insider Threat	Attack from within the organization.	Disgruntled employee	Data leakage
Zero-Day Exploit	Uses an unknown vulnerability.	Unpatched software flaw	Full system compromise

Types of Malware



Social Engineering Attacks



Cyber Attack Lifecycle (Kill Chain)

- The attack lifecycle shows the steps an attacker follows from planning to achieving their goal.

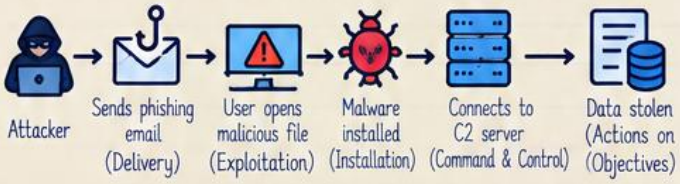


Stages of Attack Lifecycle

Stage	Description	Example
1 Reconnaissance	Attacker gathers information about the target.	Finding employee emails, scanning open ports
2 Weaponization	Creates a malicious payload using the gathered information.	Malicious document with macro
3 Delivery	Sends the payload to the target through a delivery method.	Phishing email with malicious attachment
4 Exploitation	Uses a vulnerability to execute the payload.	Exploiting a software flaw
5 Installation	Installs malware or backdoor on the target system.	Installing a ransomware
6 Command & Control (C2)	Establishes communication with the attacker's server.	Using a bot to connect to C2 server
7 Actions on Objectives	Performs the final goal (e.g., steal data, encrypt files, destroy systems).	Data exfiltration, ransomware encryption

@codedsoul_05

Attack Lifecycle Example (Real World)



Common Attack Vectors

Vector	Description
Email	Phishing, malicious attachments
Web	Drive-by downloads, malicious websites
Network	Exploiting open ports and services
Removable Media	Infected USB drives
Applications	Exploiting software vulnerabilities
Social Media	Phishing, impersonation attacks
Cloud	Misconfigured cloud services
Insider	Malicious or careless employees

Impact of Cyber Attacks

- Financial loss
- Data theft or leakage
- Reputation damage
- Service downtime
- Legal and regulatory penalties
- Loss of customer trust

Prevention and Mitigation

- Use strong passwords and MFA
- Keep software and systems updated
- Educate users about phishing
- Use firewalls and intrusion detection systems
- Monitor network activity
- Follow the principle of least privilege

15. Malware + Phishing + Social Engineering

What are they ?

- Malware is malicious software designed to damage, disrupt, or gain unauthorized access to a system.
- Phishing is a social engineering technique that tricks users into revealing sensitive information.
- Social Engineering is the manipulation of people to gain unauthorized access to systems, data, or resources.

Key Differences

Aspect	Malware	Phishing	Social Engineering
What is it ?	Malicious software	Fraudulent communication	Human manipulation
Target	Systems and data	People (via email, SMS, etc.)	People (psychological)
Method	Infection through files, links, or exploits	Fake messages or websites	Trick, build trust, or create urgency
Goal	Steal, damage, or control systems	Steal sensitive information	Gain access to data, systems, or physical locations
Example	Virus, Trojan, Ransomware	Fake email	Pretending to be IT support

Types of Malware



Virus
Attaches to files and spreads.



Worm
Self-replicates over networks.



Trojan Horse
Looks legitimate but contains malicious code.



Ransomware
Encrypts data and demands payment.



Spyware
Secretly monitors and collects data.



Adware
Shows unwanted ads.



Rootkit
Hides itself and gains deep access

Common Malware Types

@codedsoul_05

Type	Description	Example	Impact
Virus	Attaches to files and spreads when executed.	File infector	Data loss, file corruption
Worm	Self-replicates over networks without user action.	Conficker	Network slowdown
Trojan Horse	Disguised as legitimate software but performs malicious actions.	Remote Access Trojan (RAT)	Unauthorized access
Ransomware	Encrypts files and demands payment for decryption.	WannaCry, LockBit	Data loss, business disruption
Spyware	Secretly monitors user activity.	Keyloggers	Data theft, privacy breach
Adware	Displays unwanted ads.	Browser adware	Poor performance, tracking
Rootkit	Hides presence and provides deep access.	Kernel rootkit	Full system control
Bot	Turns infected device into a bot (part of botnet).	Zeus bot	Used for DDoS, spamming, etc.

Phishing



- Phishing is a cyber attack where attackers impersonate a trusted entity to steal sensitive information such as passwords, credit card details, or personal data.
- It usually happens via email, SMS, or fake websites.

Types of Phishing



Email Phishing
Fake emails



Spear Phishing
Targeted to specific person



Whaling
Targets high-profile people (e.g., CEO)



Smishing
Fake SMS messages

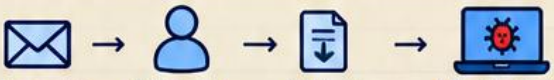


Vishing
Fake phone calls (voice phishing)

Real World Phishing Example



Attack Flow (Example: Phishing with Malware)



1. User receives phishing email (Phishing)
2. User clicks malicious link (Social Engineering)
3. Malware is downloaded (Malware)
4. System infected and attacker gains access (Malware)

Social Engineering

- Social engineering is the psychological manipulation of people to gain unauthorized access to systems, data, or resources.
- Attackers exploit human behavior, trust, and emotions instead of technical vulnerabilities.

Common Social Engineering Techniques



Pretexting
Creates a false scenario (e.g., IT support).



Baiting
Offers something attractive (e.g., free USB).



Quid Pro Quo
Offers a service in exchange for information.



Tailgating
Follows an authorized person into a secure area.



Impersonation
Pretends to be a trusted person (e.g., admin).

Examples of Social Engineering

Technique	Example	Goal
Pretexting	Fake IT support calls.	Get credentials or access.
Baiting	Free software or USB drive.	Infect system or steal data.
Quid Pro Quo	Offer technical help.	Gain sensitive information.
Tailgating	Follow someone into office.	Physical access.
Impersonation	Pretend to be CEO or admin.	Access data or systems.
Reverse Social Engineering	Attacker creates a problem and waits for victim to reach out.	Gain trust and extract info.

Impact on Organizations



Financial Loss
Ransom payments, fraud, theft



Data Breach
Sensitive data exposed



Reputation Damage
Loss of customer trust



Operational Disruption
System downtime



Legal and Regulatory Penalties
Fines and compliance issues

Prevention and Mitigation

1. Be cautious with emails, links, and attachments.
2. Verify senders and check for suspicious URLs.
3. Use antivirus and anti malware software.
4. Keep systems and software updated.
5. Enable multi factor authentication (MFA).
6. Educate users about phishing and social engineering.
7. Follow the principle of least privilege.
8. Monitor network activity for suspicious behavior.

Key Takeaways

- Malware exploits systems, phishing and social engineering exploit people.
- Always verify, don't trust blindly.
- Human error is the biggest security risk.
- Use security tools, awareness, and best practices to stay safe.

16. Web Security + OWASP Top 10

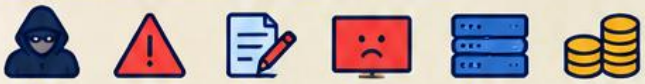
What is Web Security ?

- Web security is the practice of protecting websites, web applications, APIs, and users from attacks, unauthorized access, and data breaches.
- It ensures the confidentiality, integrity, and availability of web resources.
- It includes secure coding, proper configuration, authentication, authorization, input validation, and monitoring.

Web Application Architecture



Common Web Security Threats



OWASP Top 10 (2021)

No.	Vulnerability	Description (Short)	Example
A01	Broken Access Control	Improper restrictions on what users can access.	Accessing admin page without permission
A02	Cryptographic Failures	Sensitive data not properly encrypted.	Storing passwords in plain text
A03	Injection	Untrusted input executed as code or command.	SQL Injection, Command Injection
A04	Insecure Design	Security not considered in design phase.	Missing threat modeling
A05	Security Misconfiguration	Default or incorrect configurations.	Default admin credentials
A06	Vulnerable and Outdated Components	Using outdated libraries or software with known flaws.	Old version of jQuery / npm packages
A07	Identification and Authentication Failures	Weak or improper login mechanisms.	Weak passwords, no MFA
A08	Software and Data Integrity Failures	Untrusted code or data without proper verification.	Using tampered plugins or updates
A09	Security Logging and Monitoring Failures	Insufficient logging and monitoring.	No audit logs for suspicious activity
A10	Server-Side Request Forgery (SSRF)	Server makes unintended requests to internal systems.	Accessing internal metadata service

Types of Web Security Attacks



Secure Coding Practices

1. Validate and sanitize all user input.
2. Use parameterized queries (prevent SQL Injection).
3. Implement proper authentication and authorization.
4. Use HTTPS and secure cookies (HttpOnly, Secure, SameSite).
5. Keep libraries and frameworks updated.
6. Follow the principle of least privilege.
7. Implement proper error handling (no sensitive info in errors).
8. Enable logging and monitoring.
9. Use Content Security Policy (CSP).
10. Conduct regular security testing and code reviews.

@codedsoul_05

Goals of Web Security

Goal	Meaning	Example
Confidentiality	Only authorized users can access data.	Encryption, Access Control
Integrity	Data is not modified without authorization.	Input Validation, Hashing
Availability	Application is available to users when needed.	DDoS Protection, Proper Configuration.
Authentication	Verify the identity of users.	Login, MFA, Tokens
Authorization	Control what users can do.	Role Based Access Control
Non-repudiation	Prevent denial of actions by users.	Logging, Audit Trails

Web Security Layers (Defense in Depth)



Detailed Explanation with Examples

- **A01** **Broken Access Control** – Users can access data or functions they should not. Example: Normal user can access /admin page.
- **A02** **Cryptographic Failures** – Sensitive data is not encrypted properly. Example: Storing credit card details in plain text.
- **A03** **Injection** – Malicious input is executed by the application. Example: SQL Injection: ' OR 1=1 --
- **A04** **Insecure Design** – Security flaws in architecture or design. Example: No rate limiting on login page.
- **A05** **Security Misconfiguration** – Incorrect or default configurations. Example: Default admin credentials, unnecessary open ports.
- **A06** **Vulnerable and Outdated Components** – Using known vulnerable software. Example: Old version of library with public exploit.
- **A07** **Identification and Authentication Failures** – Weak authentication. Example: No MFA, weak password policy.
- **A08** **Software and Data Integrity Failures** – Untrusted code or updates. Example: Installing a tampered plugin.
- **A09** **Security Logging and Monitoring Failures** – Lack of logging and monitoring. Example: No logs for failed login attempts.
- **A10** **Server-Side Request Forgery (SSRF)** – Server can be tricked into making requests to internal systems. Example: Accessing cloud metadata like 169.254.169.254

Web Security Tools



Real World Example (OWASP Attack Flow)



Key Takeaways

- Web security protects users, data, and applications from attacks.
- OWASP Top 10 covers the most common and critical web application risks.
- Follow secure coding practices, proper authentication and authorization.
- Use security tools and regular testing.
- Layered security and monitoring help in early detection and response.
- Keeping systems updated and following best practices reduces the risk.

17. Network Security + IDS + IPS

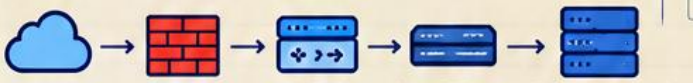
What is Network Security ?

- Network security is the practice of protecting computer networks, devices, data, and users from unauthorized access, attacks, and misuse.
- It ensures the confidentiality, integrity, and availability of data and network resources.
- It includes policies, technologies, and processes to prevent, detect, and respond to threats.

Goals of Network Security (CIA + Others)

Goal	Meaning	Example
Confidentiality	Only authorized users can access data	Encryption, Access Control
Integrity	Data is not modified without authorization	Hashing, Digital Signatures
Availability	Systems and network are available when needed	DDoS protection, redundancy
Authentication	Verify the identity of users	Passwords, MFA, Certificates
Non-repudiation	Actions cannot be denied	Logs, Digital Signatures
Access Control	Allow or deny access	Firewall, ACL, VPN

Network Security Architecture



What is IDS ?

- IDS (Intrusion Detection System) monitors network traffic and system activities to detect suspicious or malicious behavior.
- It only detects and alerts, it does not block the traffic.
- **Types:** Network-based IDS (NIDS) and Host-based IDS (HIDS).

What is IPS ?

- IPS (Intrusion Prevention System) monitors network traffic, detects malicious activity and automatically blocks it.
- It works in real-time to prevent attacks.
- **Types:** Network-based IPS (NIPS) and Host-based IPS (HIPS).

Common Network Security Threats



Firewall vs IDS vs IPS (Comparison)

Feature	Firewall	IDS	IPS
Purpose	Filters traffic based on rules	Detects malicious activity	Detects and blocks malicious activity
Action	Allow or block traffic	Alert only	Alert and block traffic
Position	Edge of network	Passive (out of band)	Inline (in the path)
Traffic Inspection	Header and basic rules	Deep packet inspection	Deep packet inspection
Real-time Blocking	Yes	No	Yes
Example Tools	Cisco ASA, pfSense	Snort, Suricata	Snort, (IPS), Cisco Firepower

How IDS and IPS Work ?

IDS (Detect and Alert)



IPS (Detect and Block)



Types of IDS and IPS

Type	Description	Example	Use Case
NIDS	Monitors network traffic (passive)	Snort, Suricata	Detect attacks on network (enterprise, data center)
HIDS	Monitors host/system logs and activities	OSSEC, Wazuh	Detect malware, file changes on servers
NIPS	Network-based, inline (prevent attacks)	Snort (IPS), Cisco Firepower	Block malicious traffic at network level
HIPS	Host-based, inline (prevent attacks)	OSSEC, CrowdStrike	Prevent attacks on individual hosts/endpoints

Common Network Security Devices and Tools



Network Attacks and Mitigation

Attack Type	Description	Example	Mitigation
DDoS Attack	Floods network with traffic	SYN Flood, UDP Flood	Firewall, DDoS Protection, Rate Limiting
Man in the Middle	Intercepts communication	ARP Spoofing	Encryption (TLS), VPN, Certificates
Port Scanning	Finds open ports	Nmap Scan	Firewall, IDS/IPS, Close unnecessary ports
Spoofing	Fakes IP/MAC address	IP Spoofing	Access Control, IDS/IPS
Malware Propagation	Spreads in network	Worm, Trojan	Antivirus, Network Segmentation
DNS Poisoning	Redirects to fake website	Fake DNS response	DNSSEC, Secure DNS
Brute Force Attack	Tries many passwords	SSH Brute Force	Account Lockout, MFA

Key Takeaways

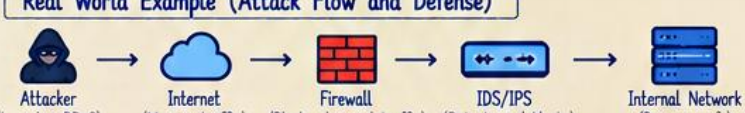
@codedsoul_05

- Use firewall, IDS/IPS and monitoring tools together.
- Follow least privilege and access control policies.
- Keep systems and network devices updated.
- Use encryption (VPN, TLS) for secure communication.
- Monitor and analyze logs using SIEM.
- Implement network segmentation.
- Use intrusion detection and prevention to detect and block attacks.
- Follow security best practices and regular vulnerability assessments.

Popular IDS/IPS Tools

Tool	Type	Description
Snort	NIDS / NIPS	Open source, widely used
Suricata	NIDS / NIPS	High performance, supports multi-threading
Zeek (Bro)	NIDS	Network traffic analysis and logging
OSSEC	HIDS	Host based IDS with log analysis
Cisco Firepower	NIPS	Enterprise grade IDS/IPS
Wazuh	HIDS	Open source, monitoring and threat detection

Real World Example (Attack Flow and Defense)



18. Wireshark + Nmap + Security Tools

What are they ?

- Wireshark is a network protocol analyzer used to capture and analyze network traffic.
- Nmap is a network scanning tool used to discover hosts, open ports, services, and vulnerabilities.
- Security tools are various tools used for network monitoring, scanning, vulnerability assessment, and incident analysis.
- These tools help in detecting, troubleshooting, and securing networks and systems.

Key Differences

Aspect	Wireshark	Nmap	Security Tools (General)
Purpose	Capture and analyze network traffic	Scan networks and find hosts, ports, services	Various security tasks (monitoring, scanning, analysis)
Type	Packet analyzer	Network scanner	Multiple types
Data	Real time network packets	Host, port, service information	Depends on tool (e.g. logs, packets, vulnerabilities)
Use Case	Troubleshooting, forensics, analysis	Reconnaissance, mapping, security audits	Monitoring, scanning, exploitation, forensics
Example Output	Packet details, protocols, payload	Open ports, OS detection, services	Alerts, reports, vulnerabilities, logs

How They Work (Overview)



Wireshark (Packet Analysis)



- Captures network packets in real time.
- Allows you to analyze protocols like TCP, UDP, HTTP.
- Useful for troubleshooting, security analysis, and incident response.

Wireshark Features

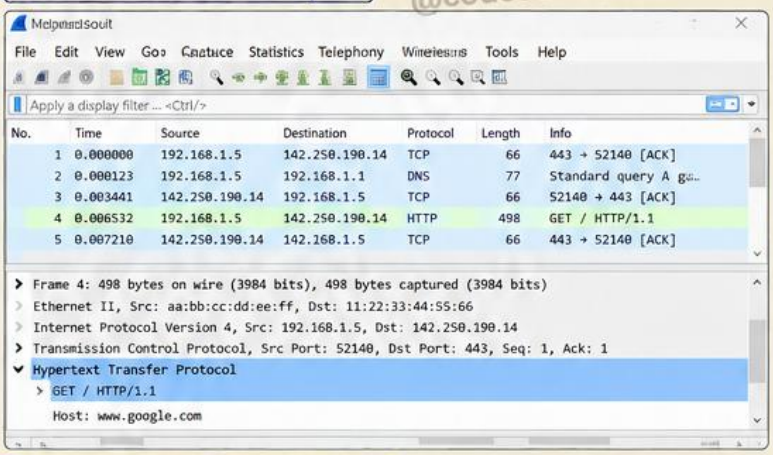
Feature	Description
Packet Capture	Captures live network traffic from interfaces.
Protocol Analysis	Decodes 1000+ protocols (HTTP, DNS, TCP, etc.).
Filters	Use display filters to find specific packets.
Follow Stream	View complete conversation (e.g. HTTP).
Export	Save packets for analysis or reporting.

Common Wireshark Filters

Filter	Meaning
ip.addr == 192.168.1.1	Traffic to/from specific IP
tcp.port == 80	HTTP traffic
http	Show only HTTP packets
dns	Show only DNS packets
tcp.flags.syn == 1	SYN packets (connection)
icmp	Show only ICMP packets

Wireshark Interface (Example)

@codedsoul_05



Nmap (Network Scanning)



- Discovers live hosts on a network.
- Scans for open ports, services, and OS.
- Helps in network mapping, vulnerability assessment, and security auditing.

Nmap Features

Feature	Description
Host Discovery	Finds live hosts on a network.
Port Scanning	Detects open ports (TCP/UDP).
Service Detection	Identifies running services and versions.
OS Detection	Guesses the operating system.
Scripting Engine	Uses NSE scripts for advanced scanning.

Common Nmap Commands

Command	Description
nmap 192.168.1.0/24	Scan entire subnet
nmap -sn 192.168.1.0/24	Discover live hosts (ping scan)
nmap -sS 192.168.1.1	TCP SYN scan (stealth scan)
nmap -sU 192.168.1.1	UDP scan
nmap -sV 192.168.1.1	Detect service versions
nmap -O 192.168.1.1	Detect operating system
nmap --script vuln 192.168.1.1	Run vulnerability scripts
nmap -A 192.168.1.1	Aggressive scan (OS, version, scripts)

Nmap Output Example

@codedsoul_05

```
$ nmap -sV 192.168.1.1
Starting Nmap 7.94 ( https://nmap.org ) at 2026-09-21 10:00 IST
Nmap scan report for 192.168.1.1
Host is up (0.0023s latency).

PORT     STATE  SERVICE    VERSION
22/tcp   open   ssh        OpenSSH 8.2p1 (Ubuntu)
80/tcp   open   http       nginx 1.18.0
443/tcp  open   https      nginx 1.18.0

Nmap done: 1 IP address (1 host up) scanned in 2.34 seconds
```

Other Important Security Tools



- **Metasploit** (Penetration Testing)
- **Burp Suite** (Web Security Testing)
- **Nessus** (Vulnerability Scanning)
- **OpenVAS** (Vulnerability Management)
- **Nikto** (Web Server Scanning)
- **tcpdump** (Command line Packet Capture)
- **Netcat** (Network Utility)
- **Aircrack-ng** (WiFi Security Testing)
- **Hashcat** (Password Cracking)
- **John the Ripper** (Password Cracking)
- **SIEM Tools** (Log Monitoring and Analysis)

Use Cases

- Monitor and analyze suspicious network traffic.
- Identify unauthorized access or malicious activity.
- Scan networks for open ports and vulnerable services.
- Perform penetration testing and security audits.
- Troubleshoot network and application issues.
- Support incident response and digital forensics.

Best Practices

1. Use these tools only on authorized networks.
2. Keep tools updated to latest version.
3. Use filters and specific scans to avoid noise.
4. Combine multiple tools for better analysis.
5. Follow legal and ethical guidelines.

Key Takeaways

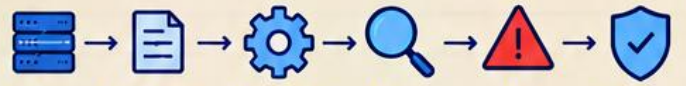
- Wireshark helps you see what is happening on the network.
- Nmap helps you find what is running on the network.
- Security tools together provide a complete view for detection, analysis, and prevention.
- They are essential for network security, troubleshooting, and incident response.

19. SIEM + Incident Response + Security Best Practices

What is SIEM ?

- SIEM (Security Information and Event Management) is a centralized system that collects, analyzes, and correlates security logs from different sources in real time.
- It helps in detecting threats, monitoring security events, and supporting incident response.
- Examples: Splunk, IBM QRadar, Microsoft Sentinel, Elastic SIEM, LogRhythm.

How SIEM Works ?



Data Sources (Logs) → Log Collection (Agents / Syslog) → Normalization (Parse & Enrich) → Analysis (Correlation & Detection) → Alert (Threat Detected) → Response (Take Action)

Goals of SIEM

Goal	Meaning
Centralized Logging	Collect logs from multiple sources (servers, network, applications, endpoints, cloud).
Real-time Monitoring	Monitor and analyze events in real time.
Threat Detection	Identify suspicious and malicious activities.
Correlation	Combine multiple events to detect complex attacks.
Compliance	Help meet regulatory requirements (ISO, GDPR, etc.).
Incident Response	Provide alerts, reports, and forensic data.

Common SIEM Tools

Splunk · IBM QRadar · Microsoft Sentinel · Elastic SIEM · LogRhythm

Key SIEM Components

Component	Description
Log Sources	Devices, servers, applications, network devices, cloud services, endpoints.
Collectors (Agents)	Collect and forward logs to SIEM.
Normalization	Convert logs into a common format.
Correlation Engine	Analyze and correlate events to detect threats.
Alerting	Generate alerts for suspicious activities.
Dashboards	Visualize logs, alerts, and reports.
Retention	Store logs for future analysis and compliance.

Types of Logs in SIEM

Log Type	Example
System Logs	Windows Event Logs, Linux syslog
Application Logs	Web server logs, database logs
Network Logs	Firewall, IDS/IPS, VPN logs
Security Logs	Authentication, authorization logs
Cloud Logs	AWS CloudTrail, Azure Activity Logs
Endpoint Logs	EDR, antivirus logs
Audit Logs	User activity, file access logs

Example SIEM Dashboard (Concept)

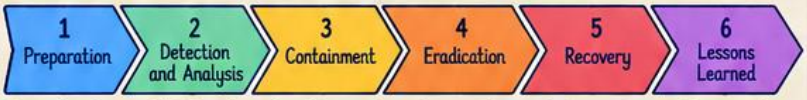


@codedsoul_05

What is Incident Response ?

- Incident response is a structured approach to detect, contain, analyze, and recover from security incidents.
- It helps minimize damage, reduce downtime, and prevent future attacks.

Incident Response Lifecycle (NIST)



1. Preparation — Be ready with tools, policies and team.
2. Detection and Analysis — Identify and analyze the incident.
3. Containment — Stop the spread of the attack.
4. Eradication — Remove the threat completely.
5. Recovery — Restore systems and services.
6. Lessons Learned — Review and improve processes.

Phases of Incident Response (Details)

Phase	Description	Activities	Example
Preparation	Build readiness and capabilities.	Create IR plan, tools, team training, backups.	Set up SIEM, define roles.
Detection and Analysis	Identify and understand incident.	Monitor alerts, analyze logs, confirm incident.	SIEM alert for brute force.
Containment	Limit the impact and stop spread.	Isolate affected systems, block malicious IPs.	Disconnect infected server.
Eradication	Remove the threat.	Delete malware, patch vulnerabilities.	Remove backdoor, apply patches.
Recovery	Restore normal operations.	Bring systems back online, monitor for issues.	Restore from clean backup.
Lessons Learned	Improve for future.	Post-incident review, update policies.	Update security controls.

Common Incident Types



Malware Infection · Unauthorized Access · Data Breach · Ransomware Attack · DDoS Attack · Phishing Incident · Insider Threat · System Misconfiguration

Important Incident Response Tools



Wireshark (Network Analysis) · NMAP (Network Scanning) · Splunk (Log Analysis) · ELK Stack (Elastic SIEM) · Volatility (Memory Forensics) · TheHive (Incident Management)

Security Best Practices

Area	Best Practices
Access Control	Use strong passwords, MFA, and least privilege.
System Hardening	Disable unnecessary services, keep systems updated.
Network Security	Use firewalls, IDS/IPS, and network segmentation.
Monitoring & Logging	Enable logging and use SIEM for real time monitoring.
Data Protection	Encrypt data at rest and in transit.
Incident Response	Have a documented IR plan and conduct regular drills.
Vulnerability Management	Perform regular scanning and patching.
User Awareness	Conduct security training to prevent phishing and social engineering.
Backup & Recovery	Maintain regular backups and test recovery.
Compliance	Follow standards like ISO 27001, GDPR, PCI DSS, etc.

Key Takeaways

1. SIEM provides real time visibility and helps detect threats.
2. Incident response reduces damage and ensures quick recovery.
3. Security best practices prevent many attacks before they happen.
4. Use a combination of tools, processes, and people.
5. Monitor, detect, respond, and continuously improve.
6. Follow industry standards and keep systems updated.
7. Human awareness is as important as technology.

Popular Standards and Frameworks

- NIST Incident Response Framework
- ISO 27001
- CIS Controls
- MITRE ATT&CK
- GDPR
- PCI DSS
- SOC 2
- ITIL (for incident management)

20. Cybersecurity + Networking Cheat Sheet + 100 Interview Questions

Cybersecurity Networking OSI Model

Layer	Name	Example	Security Focus
7	Application	HTTP, FTP, DNS, SMTP	Input validation, WAF, authentication
6	Presentation	SSL/TLS, JPEG, MPEG	Encryption, data encoding
5	Session	NetBIOS, RPC	Session management, timeouts
4	Transport	TCP, UDP	Firewall, port filtering, DoS protection
3	Network	IP, ICMP, IPSec	Routing security, IDS/IPS
2	Data Link	MAC, Switch	Port security, VLAN, ARP protection
1	Physical	Cables, Hubs	Physical security, access control

Common TCP/IP Protocols

Protocol	Port	Use Case
HTTP	80	Web traffic (not secure)
HTTPS	443	Secure web traffic
FTP	21	File transfer
SSH	22	Secure remote login
Telnet	23	Remote login (insecure)
SMTP	25	Send email
DNS	53	Domain name resolution
DHCP	67/68	IP address assignment
RDP	3389	Remote desktop
SNMP	161	Network management
NTP	123	Time synchronization
POP3	110	Receive email
IMAP	143	Receive email (sync)
LDAP	389	Directory services
SMB	445	File sharing (Windows)

Common Cybersecurity Ports

Port	Service	Risk
21	FTP	Unencrypted data
22	SSH	Brute force attempts
23	Telnet	Insecure, sniffing risk
25	SMTP	Spam, email spoofing
53	DNS	DDoS, DNS poisoning
80	HTTP	Insecure traffic
110	POP3	Credential theft
143	IMAP	Email account access
443	HTTPS	Secure traffic (still monitor)
445	SMB	Lateral movement (ransomware)
3389	RDP	Brute force, remote access
8080	Proxy	Common alternate port
8443	HTTPS (alt)	Misconfigured services

Common Network Devices



Router — Routes traffic between networks



Switch — Connects devices in same network



Firewall — Filters allowed blocked traffic



IDS — Detects malicious activity



IPS — Blocks malicious activity



Load Balancer — Distributes traffic



Access Point — Provides WiFi access



Proxy — Acts as intermediary



NAC — Controls device access



SIEM — Collects and analyzes logs

Common Cybersecurity Terms

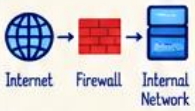
Term	Meaning
Vulnerability	Weakness in a system
Threat	Potential danger
Exploit	Code that uses a vulnerability
Payload	Malicious code executed
Malware	Malicious software
Ransomware	Encrypts data and demands payment
Phishing	Trick users to steal information
DoS/DDoS	Overwhelms system with traffic
SOC	Security Operations Center
MFA	Multi Factor Authentication
Zero Trust	No implicit trust, verify everything
Encryption	Converts data to unreadable form
Hashing	Converts data to fixed length string
SIEM	Collects and correlates security logs

Cybersecurity Kill Chain

1. **Reconnaissance** — Gather information about target
2. **Weaponization** — Create malicious payload
3. **Delivery** — Send via email, web, or network
4. **Exploitation** — Use vulnerability to gain access
5. **Installation** — Install malware
6. **Command & Control** — Maintain remote access
7. **Actions on Objectives** — Steal data, disrupt, or destroy

Network Security Models

Perimeter Security



Block unauthorized access at the boundary

Zero Trust Architecture



Verify every request, never trust by default

Cybersecurity Best Practices

1. Use strong and unique passwords.
2. Enable Multi Factor Authentication (MFA).
3. Keep systems and software updated.
4. Follow least privilege access.
5. Use firewalls, IDS/IPS, and monitoring tools.
6. Encrypt sensitive data.
7. Regularly backup data and test recovery.
8. Conduct security awareness training.
9. Perform vulnerability assessments and patching.
10. Follow incident response plan.

Common Security Tools Cheat Sheet

Tool	Category	Use Case
Wireshark	Packet Analyzer	Network traffic analysis
Nmap	Network Scanner	Discover hosts and open ports
Metasploit	Penetration Testing	Exploit vulnerabilities (ethical)
Burp Suite	Web Security	Web app testing (OWASP)
Nessus	Vulnerability Scanner	Find vulnerabilities
OpenVAS	Vulnerability Scanner	Open source scanner
Snort	IDS/IPS	Detect network attacks
Suricata	IDS/IPS	Network threat detection
Splunk	SIEM	Log analysis and monitoring
Wazuh	HIDS/SIEM	Host and log monitoring
ELK Stack	SIEM	Log collection and analysis
Hashcat	Password Cracking	Crack password hashes
John the Ripper	Password Cracking	Password auditing
Aircrack-ng	WiFi Security	Wireless network testing
Sqlmap	Web Security	Automated SQL injection testing

Common Firewall Rules (Examples)

Rule	Purpose
Allow HTTPS (port 443)	Allow secure web traffic
Allow SSH (port 22)	Secure remote access
Block Telnet (port 23)	Prevent insecure access
Allow DNS (port 53)	Allow domain resolution
Block unnecessary ports	Reduce attack surface
Allow internal networks	Permit trusted IP ranges
Enable logging	Monitor and audit traffic

Common Commands Cheat Sheet

Command	Use Case
ipconfig / ifconfig	View IP configuration
ping	Test connectivity
tracert / traceroute	Trace network path
netstat -an	View active connections
nslookup	DNS lookup
nmap -sS <IP>	Port scan (stealth scan)
nmap -sV <IP>	Detect service versions
tcpdump	Capture network packets
curl -I <URL>	Check HTTP headers
openssl s_client -connect	Test SSL/TLS connection

100 Cybersecurity + Networking Interview Questions (Categorized)

1. Networking Basics (10)

1. What is an IP address
2. Difference between TCP and UDP
3. What is DNS and how it works
4. What is a subnet and subnet mask
5. What is NAT
6. What is a router and switch
7. What is ARP
8. What is VLAN
9. What is a default gateway
10. What is a MAC address

2. Network Security (10)

11. What is a firewall
12. Difference between IDS and IPS
13. What is a DMZ
14. What is a VPN
15. Types of firewalls
16. What is port forwarding
17. What is packet filtering
18. What is a proxy server
19. What is network segmentation
20. How to prevent DDoS attacks

3. Cybersecurity Concepts (10)

21. What is a vulnerability
22. What is a threat and exploit
23. What is malware
24. Types of malware
25. What is ransomware
26. What is phishing
27. What is social engineering
28. What is zero day attack
29. What is the CIA triad
30. What is the principle of least privilege

4. Web Security (10)

31. What is SQL injection
32. What is XSS
33. What is CSRF
34. What is input validation
35. What is a WAF
36. What is HTTPS and SSL/TLS
37. What is a session hijacking
38. What is cookie and how to secure it
39. What is OWASP Top 10
40. How to prevent web attacks

5. Tools and Practical (10)

41. Wow to Wireshark and how to use it
42. What is Nmap and common options
43. What is Metasploit
44. What is Burp Suite
45. What is Nessus
46. What is Snort
47. What is Splunk
48. What is Hashcat
49. What is Aircrack-ng
50. What is the ELK Stack

6. SIEM and Monitoring (10)

51. What is SIEM
52. What are logs
53. What is correlation
54. What is a SOC
55. What is a false positive
56. What is log aggregation
57. What is real time monitoring
58. What is threat hunting
59. What is UEBA
60. Which SIEM tools are popular

7. Incident Response (10)

61. What is incident response
62. Phases of incident response
63. What is a security incident
64. How to detect a breach
65. What is forensic analysis
66. What is malware analysis
67. What is a playbook
68. How to contain an incident
69. What is post incident review
70. What is disaster recovery

8. Risk and Compliance (10)

71. What is risk management
72. What is a risk assessment
73. What is ISO 27001
74. What is GDPR
75. What is PCI DSS
76. What is SOC 2
77. What is HIPAA
78. What is compliance vs security
79. What is a security policy
80. What is data privacy

9. Advanced Topics (10)

81. What is threat intelligence
82. What is MITRE ATT&CK
83. What is honeypot
84. What is sandboxing
85. What is EDR and XDR
86. What is endpoint security
87. What is privilege escalation
88. What is lateral movement
89. What is zero trust
90. What is cloud security

10. Scenario Based (10)

91. How to handle a suspected breach
92. Steps to investigate a phishing email
93. How to secure a web application
94. How to design a secure network
95. How to respond to a ransomware attack
96. How to reduce attack surface
97. How to configure firewall rules
98. How to monitor suspicious activity
99. How to prepare an incident report
100. Best practices for overall security

@codedsoul_05